

DOSSIER D'ARCHITECTURE ET D'EXPLOITATION

Workshop Évalué — Ingénierie de l'Observabilité Sécurisée

M2-Shop — Plateforme de commerce électronique

Section 3 — Plan de Continuité Opérationnelle

Section 3 — Plan de Continuité Opérationnelle

3.1 Procédure d'Isolation d'Urgence d'un Serveur Web Compromis

Cette procédure s'applique lorsqu'un indicateur de compromission (IOC) est détecté sur le serveur web de production web-prod (10.0.20.20). Elle vise à confiner l'incident en moins de 10 minutes, limiter la propagation latérale, et préserver les éléments de preuve nécessaires à l'investigation forensique ultérieure.

⚠ IMPORTANT : Seul un membre de l'équipe SRE/SOC habilité peut exécuter cette procédure. Toute action doit être horodatée et consignée dans le rapport post-mortem correspondant.

Prérequis

- Accès SSH au serveur fw-router (10.0.20.1 / 10.0.10.1)
- Accès SSH au serveur web-prod (10.0.20.20) — si encore possible
- Accès à la console Grafana (<https://10.0.10.5:3000>) et Alertmanager (<http://10.0.10.5:9093>)
- Droits sudo sur fw-router et web-prod

Phase 1 — Détection et confirmation (Objectif : < 2 min)

1. Vérifier l'alerte dans Grafana ou sur le canal Slack #alertes-m2shop. Identifier la nature de l'IOC (comportement réseau anormal, pic de CPU/mémoire inexpliqué, processus inconnus, logs Nginx suspects, etc.).
2. Confirmer l'état du serveur depuis la zone Admin (sans se connecter directement à web-prod) :

```
ssh user@10.0.10.5 # depuis supervision
curl -k -s -o /dev/null -w '%{http_code}' https://10.0.20.20/ # vérifier la
disponibilité Nginx
```
3. Consulter les logs Nginx dans Grafana (datasource Loki) pour identifier les tentatives d'exploitation ou les requêtes anormales.
4. Prendre une décision d'isolation : si le doute persiste, appliquer le principe de précaution et passer à la Phase 2.

Phase 2 — Confinement réseau d'urgence (Objectif : < 5 min)

⚠ IRRÉVERSIBLE : Les commandes ci-dessous coupent tout flux réseau vers/depuis web-prod, y compris Prometheus et Zabbix. Le serveur sera invisible de la zone Admin. L'impact client sera immédiat : le service web public M2-Shop sera indisponible.

Connexion au routeur inter-zones (seul point de contrôle réseau entre les zones Prod et Admin) :

```
ssh user@fw-router
```

Ajout d'une règle de DROP total sur web-prod en priorité haute, avant toutes les règles existantes :

```
# Isolation immédiate de web-prod dans la chaîne FORWARD
sudo nft insert rule inet filter forward \
    ip saddr 10.0.20.20 counter drop
sudo nft insert rule inet filter forward \
    ip daddr 10.0.20.20 counter drop
```

Vérification que le confinement est actif (les compteurs doivent s'incrémenter) :

```
sudo nft list chain inet filter forward
```

Si l'accès SSH à web-prod est encore disponible et qu'une isolation locale renforcée est nécessaire (double-boucle de sécurité) :

```
ssh user@10.0.20.20
sudo nft flush ruleset
sudo nft add table inet filter
sudo nft add chain inet filter input '{ type filter hook input priority 0 ; policy drop ; }'
sudo nft add chain inet filter output '{ type filter hook output priority 0 ; policy drop ; }'
# Garder uniquement SSH depuis la zone Admin pour ne pas perdre la session
sudo nft add rule inet filter input ip saddr 10.0.10.0/24 tcp dport 22 accept
```

Phase 3 — Préservation des preuves (Objectif : < 8 min)

5. Depuis fw-router, capturer le trafic réseau restant pour l'investigation :

```
sudo tcpdump -i eth1 host 10.0.20.20 -w /tmp/capture-incident-$(date +%Y%m%d-%H%M%S).pcap &
```

6. Depuis web-prod (si SSH encore disponible), archiver les logs :

```
sudo tar czf /tmp/logs-incident-$(date +%Y%m%d-%H%M%S).tar.gz \
    /var/log/nginx/ /var/log/zabbix/ /var/log/healer/ /var/log/auth.log
```

7. Exporter la liste des processus en cours et des connexions réseau établies :

```
sudo ps auxf > /tmp/processes-$(date +%Y%m%d-%H%M%S).txt
sudo ss -tulpn > /tmp/netstat-$(date +%Y%m%d-%H%M%S).txt
```

8. Transférer les archives vers la zone Admin pour analyse sécurisée :

```
scp /tmp/logs-incident-*.tar.gz user@10.0.10.5:/tmp/forensics/
scp /tmp/processes-*.txt /tmp/netstat-*.txt user@10.0.10.5:/tmp/forensics/
```

Phase 4 — Notification et escalade (Objectif : < 10 min)

9. Ouvrir un ticket d'incident en mentionnant : heure de détection, IOC identifiés, actions déjà effectuées, impacts.
10. Notifier le responsable sécurité et la hiérarchie directe.

11. Silencer les alertes Prometheus/Alertmanager pour web-prod pendant l'investigation (pour éviter le bruit) :

```
amtool silence add --alertname=NginxDn \
  --comment='Incident en cours - isolement volontaire' \
  --duration=4h \
  alertmanager.url=http://10.0.10.5:9093
```

12. Conserver cette procédure ouverte et renseigner les horodatages de chaque action dans le template post-mortem ci-après.

Phase	Objectif	Action clé	Délai cible
1 — Détection	Confirmer l'IOC	Alerte Grafana/Slack + curl sanity check	< 2 min
2 — Confinement	Couper les flux réseau	nft insert rule DROP sur fw-router	< 5 min
3 — Préservation	Protéger les éléments de preuve	Capture réseau + archive logs	< 8 min
4 — Escalade	Notifier les parties prenantes	Ticket + silence Alertmanager	< 10 min

Tableau 3.1 — Synthèse des phases d'isolation d'urgence avec délais cibles

Rétablissement du service

Le rétablissement n'est effectué qu'après analyse complète des preuves et confirmation que le serveur est sain (ou après substitution par une nouvelle instance reconstruite depuis l'IaC).

Procédure inverse :

- Reconstruction du serveur depuis le Vagrantfile + Ansible (RTO mesuré en TP : < 10 min)
- Validation des règles nftables avant de lever l'isolation sur fw-router
- Rejouer les tests de validation des Jalons A, B, C, D avant remise en service
- Lever le silence Alertmanager et confirmer la reprise de supervision

3.2 Template Vierge de Rapport Post-Mortem d'Incident

Ce template standardisé est à compléter dans les 24 à 48 heures suivant la résolution de l'incident. Il s'inspire des pratiques SRE (Google SRE Book) et des recommandations ANSSI en matière de gestion d'incidents de sécurité.

 **Blameless Post-Mortem** : Ce rapport est rédigé dans une culture sans blame. L'objectif est d'identifier les causes systémiques, pas de désigner des responsables individuels. Toute information partagée sert à améliorer le système, pas à sanctionner.

Champ	Valeur
Titre de l'incident	[Description courte — ex : Indisponibilité Nginx web-prod suite compromission]
Date / Heure de début	AAAA-MM-JJ HH:MM UTC
Date / Heure de résolution	AAAA-MM-JJ HH:MM UTC
Durée totale	[X heures Y minutes]
Sévérité	☐ Critique ☐ Haute ☐ Moyenne ☐ Basse
Services impactés	[ex : Service web public M2-Shop, supervision Prometheus/Zabbix]
Rédigé par	[Prénom Nom] — [Rôle]
Relecteurs	[Prénom Nom] — [Rôle]
Date de revue	AAAA-MM-JJ

Tableau 3.2 — Métadonnées de l'incident

Résumé exécutif

[2 à 4 phrases maximum. Décrire ce qui s'est passé, quel a été l'impact utilisateur/métier, et comment l'incident a été résolu. Ce résumé doit être compréhensible par un public non technique.]

Impact

Dimension	Description
Impact utilisateurs	[Ex : Service web indisponible pendant X min. Nb d'utilisateurs impactés estimé : Y]
Impact données	[Ex : Aucune perte de données / Fuite suspectée sur les logs applicatifs]
Impact réputationnel	[Ex : Non visible pour les clients / Signalement presse]
Impact financier estimé	[Ex : X € de perte de chiffre d'affaires estimée]
SLO impacté	[Ex : Disponibilité cible 99,9 % — violation constatée sur la fenêtre mensuelle]

Chronologie détaillée

Renseigner chaque action, observation ou décision avec son horodatage précis (UTC). Ne rien omettre, même les actions qui s'avèrent a posteriori sans rapport direct.

Heure (UTC)	Acteur	Événement / Action
HH:MM:SS	[Alertmanager / Personne]	[ex : Alerte NginxDown firing reçue sur Slack]
HH:MM:SS	[SRE]	[ex : Connexion SSH sur fw-router pour diagnostic]
HH:MM:SS	[SRE]	[ex : Isolation réseau de web-prod via nft]
HH:MM:SS	[SRE]	[ex : Archive des logs transférée vers supervision]
HH:MM:SS	[SRE]	[ex : Reconstruction du serveur depuis l'IaC (Vagrant + Ansible)]
HH:MM:SS	[SRE]	[ex : Validation des tests des Jalons A-D — service remis en production]
HH:MM:SS	[Alertmanager]	[ex : Alerte NginxDown resolved — fin de l'incident]

Tableau 3.3 — Chronologie détaillée de l'incident (à compléter)

Analyse des causes racines (RCA)

Utiliser la méthode des 5 Pourquoi ou le diagramme d'Ishikawa pour identifier les causes profondes, pas seulement les symptômes immédiats.

Niveau	Pourquoi ?
1	[Symptôme direct — ex : Nginx s'est arrêté]
2	[Cause immédiate — ex : Un processus inconnu a épuisé les ressources système]
3	[Cause intermédiaire — ex : Une vulnérabilité dans le vhost a permis l'exécution de code distant]
4	[Cause systémique — ex : La version Nginx n'était pas à jour, la politique de mise à jour était manuelle]
5	[Cause racine — ex : Absence de processus automatisé de patch management et d'audit de vulnérabilités]

Tableau 3.4 — Analyse par la méthode des 5 Pourquoi

Facteurs contributants

- Facteur technique : [ex : Absence de WAF devant le serveur Nginx]
- Facteur process : [ex : Délai entre la publication du patch CVE et son application en production]
- Facteur humain : [ex : Alerte non actionnée rapidement car canal de notification non surveillé hors heures ouvrées]
- Facteur outillage : [ex : Le dashboard Grafana n'exposait pas encore le taux de requêtes anormales en temps réel au moment de l'incident]

Ce qui a bien fonctionné

- [ex : Le mécanisme d'auto-healing Alertmanager → webhook receiver a relancé Nginx en 5 secondes sans intervention humaine]
- [ex : L'architecture Zero-Trust a limité le blast radius : la compromission de web-prod n'a pas permis d'atteindre la zone Admin]
- [ex : Les logs Nginx centralisés dans Loki ont permis de reconstituer la timeline d'attaque en moins de 10 minutes]
- [ex : La procédure d'isolation a été exécutée conformément à la durée cible de 10 minutes]

Ce qui aurait pu être mieux

- [ex : L'alerte de détection d'anomalie de trafic réseau n'existait pas — seule la panne complète de Nginx était surveillée]
- [ex : La procédure d'isolation n'était pas encore documentée au moment de l'incident — délai supplémentaire de 3 minutes]
- [ex : L'isolation locale sur web-prod (double-boucle de sécurité) n'avait pas été testée préalablement en exercice]

Plan d'actions correctives

Action	Responsable	Priorité	Échéance
[ex : Implémenter une règle Prometheus sur le taux de 4xx/5xx Nginx]	[Prénom Nom]	Haute	JJ/MM/AAAA
[ex : Ajouter un scan automatique de vulnérabilités (Trivy, Gype) dans le pipeline CI]	[Prénom Nom]	Haute	JJ/MM/AAAA
[ex : Réaliser un exercice d'isolation trimestriel (GameDay / chaos engineering)]	[Prénom Nom]	Moyenne	JJ/MM/AAAA
[ex : Documenter la procédure de rétablissement dans le runbook d'exploitation]	[Prénom Nom]	Moyenne	JJ/MM/AAAA
[ex : Mettre en place un astreinte on-call avec rotation hebdomadaire]	[Prénom Nom]	Basse	JJ/MM/AAAA

Tableau 3.5 — Plan d'actions correctives post-incident

Métriques de l'incident

Métrique	Valeur mesurée
MTTD (Mean Time To Detect)	[ex : 8 secondes — alerte Prometheus quasi instantanée]
MTTA (Mean Time To Acknowledge)	[ex : 4 minutes — délai de prise en charge par un SRE]
MTTR (Mean Time To Recover)	[ex : 47 minutes — reconstruction IaC + validation]
Durée d'indisponibilité totale	[ex : 47 minutes]
Nb d'actions correctives identifiées	[ex : 5 actions, dont 2 priorité haute]

Tableau 3.6 — Métriques de l'incident

Signatures et validation

Rôle	Nom	Signature / Date
Auteur du post-mortem		
Responsable SRE / SOC		
RSSI / Responsable sécurité		

 **Pièces jointes à ce rapport :** Archive des logs (/tmp/logs-incident-*.tar.gz) · Capture réseau (/tmp/capture-incident-*.pcap) · Liste des processus et connexions au moment de l'incident · Captures d'écran Grafana (dashboard Observabilité Unifiée)